



ZAP Scanning Report

Site: <http://host.docker.internal:8080>

Generated on Mon, 22 Jun 2026 05:47:55

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	5
Informational	3
False Positives:	0

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	2
Directory Browsing	Medium	3
Missing Anti-clickjacking Header	Medium	1
Cookie No HttpOnly Flag	Low	4
Cookie without SameSite Attribute	Low	4
In Page Banner Information Leak	Low	1
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	5
Authentication Request Identified	Informational	1
Session Management Response Identified	Informational	2
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
--------	--

Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8080/sitemap.xml
Node Name	http://host.docker.internal:8080/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Directory Browsing
Description	It is possible to view the directory listing. Directory listing may reveal hidden scripts, include files, backup source files, etc. which can be accessed to read sensitive information.
URL	http://host.docker.internal:8080/dvwa/
Node Name	http://host.docker.internal:8080/dvwa/
Method	GET
Parameter	
Attack	http://host.docker.internal:8080/dvwa/
Evidence	Parent Directory

Other Info	
URL	http://host.docker.internal:8080/dvwa/css/
Node Name	http://host.docker.internal:8080/dvwa/css/
Method	GET
Parameter	
Attack	http://host.docker.internal:8080/dvwa/css/
Evidence	Parent Directory
Other Info	
URL	http://host.docker.internal:8080/dvwa/images/
Node Name	http://host.docker.internal:8080/dvwa/images/
Method	GET
Parameter	
Attack	http://host.docker.internal:8080/dvwa/images/
Evidence	Parent Directory
Other Info	
Instances	3
Solution	Disable directory browsing. If this is required, make sure the listed files does not induce risks.
Reference	https://httpd.apache.org/docs/current/mod/core.html#options
CWE Id	548
WASC Id	48
Plugin Id	0

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	1
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021

WASC Id	15
Plugin Id	10020

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	security
Attack	
Evidence	Set-Cookie: security
Other Info	
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	security
Attack	
Evidence	Set-Cookie: security
Other Info	
Instances	4
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly

CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	security
Attack	
Evidence	Set-Cookie: security
Other Info	
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	security
Attack	
Evidence	Set-Cookie: security
Other Info	
Instances	4
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.

Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	In Page Banner Information Leak
Description	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.
URL	http://host.docker.internal:8080/sitemap.xml
Node Name	http://host.docker.internal:8080/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.25
Other Info	There is a chance that the highlight in the finding is on a value in the headers, versus the actual matched string in the response body.
Instances	1
Solution	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/
CWE Id	497
WASC Id	13
Plugin Id	10009

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://host.docker.internal:8080/dvwa/css/login.css
Node Name	http://host.docker.internal:8080/dvwa/css/login.css
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://host.docker.internal:8080/dvwa/images/RandomStorm.png
Node Name	http://host.docker.internal:8080/dvwa/images/RandomStorm.png
Method	GET

Parameter	
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://host.docker.internal:8080/dvwa/images/login_logo.png
Node Name	http://host.docker.internal:8080/dvwa/images/login_logo.png
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://host.docker.internal:8080/robots.txt
Node Name	http://host.docker.internal:8080/robots.txt
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://host.docker.internal:8080/sitemap.xml
Node Name	http://host.docker.internal:8080/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

URL	http://host.docker.internal:8080/dvwa/css/login.css
Node Name	http://host.docker.internal:8080/dvwa/css/login.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8080/dvwa/images/RandomStorm.png
Node Name	http://host.docker.internal:8080/dvwa/images/RandomStorm.png
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8080/dvwa/images/login_logo.png
Node Name	http://host.docker.internal:8080/dvwa/images/login_logo.png
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	

Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8080/robots.txt
Node Name	http://host.docker.internal:8080/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	5
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php ()(Login,password,user_token,username)
Method	POST
Parameter	Login
Attack	
Evidence	password
Other Info	userParam=Login userValue=Login passwordParam=password referer=http://host.docker.internal:8080/login.php csrfToken=user_token
Instances	1

Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Session Management Response Identified
---------------	--

Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	PHPSESSID
Other Info	cookie:PHPSESSID
URL	http://host.docker.internal:8080/login.php
Node Name	http://host.docker.internal:8080/login.php
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	PHPSESSID
Other Info	cookie:PHPSESSID
Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
---------------	-------------------

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://host.docker.internal:8080
Node Name	http://host.docker.internal:8080
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Evidence	
Other Info	
URL	http://host.docker.internal:8080/
Node Name	http://host.docker.internal:8080/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://host.docker.internal:8080/dvwa/css
Node Name	http://host.docker.internal:8080/dvwa/css
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

Sequence Details

With the associated active scan results.